

Aplicación de Seguridad en el Ciclo de Vida del Desarrollo de Software para MediCheck

Introducción

Actualmente la seguridad de la información es básicamente un pilar fundamental dentro del desarrollo de software, especialmente en aplicaciones que manejan datos sensibles como los personales y médicos. La empresa **CyberHealth Solutions**, al desarrollar la aplicación web **MediCheck**, enfocada a la gestión de pacientes, citas y recordatorios automáticos para clínicas privadas, se encuentra ante el reto de proteger la confidencialidad, integridad y disponibilidad de los datos.

El Ciclo de Vida del Desarrollo Seguro de Software integra la seguridad como un componente transversal en todas las fases del desarrollo, desde la obtención de requerimientos hasta el mantenimiento. La correcta aplicación permite anticipar riesgos, definir controles apropiados y garantizar que las medidas de seguridad se mantengan vigentes durante toda la vida útil del sistema.

Tabla Resumen, aplicando seguridad en cada fase del SDLC

Fase del SDLC	Riesgos o Amenazas	Controles o Medidas de Seguridad	Herramienta / Estándar Sugerido
1. Requisitos	Requisitos de seguridad incompletos o ambiguos; falta de definición de privacidad de datos. Falta de claridad sobre qué es un "dato privado".	Definir requisitos de seguridad específicos (autenticación, cifrado, auditoría); aplicar análisis de riesgo inicial, para después en todo lo que resta del ciclo de vida ya tener claro qué es lo más importante.	ISO 27001, OWASP ASVS, NIST SP 800-64

Fase del SDLC	Riesgos o Amenazas	Controles o Medidas de Seguridad	Herramienta / Estándar Sugerido
2. Diseño	Arquitectura insegura, diseño sin separación de capas o un correcta segregación de módulos, mala gestión de roles o privilegios.	Aplicar principios de diseño seguro, los cuáles pueden ser: mínimo privilegio, defensa en profundidad, validación de entrada. Ya que controlando las entradas se pueden evitar varios riesgos.	OWASP SAMM, Threat Modeling (STRIDE), ISO 27034
3. Desarrollo	Código vulnerable, sin implementación de buenas prácticas, falta de estandarización que pueden dar lugar a: inyección SQL o ataques XSS; uso de librerías inseguras, falta de actualización de frameworks y nula investigación sobre estos mismos.	Revisiones de código, análisis estático (SAST), uso de repositorios confiables y control de dependencias. Cada herramienta que se utilice tiene que ser estudiada y evaluada previamente.	OWASP Top 10, SonarQube, GitHub Dependabot
4. Pruebas	Fallas no detectadas en seguridad, pruebas insuficientes o deficientes que no están automatizadas y no permiten ver realmente todas las vulnerabilidades que puedan existir.	Implementar pruebas de penetración, análisis dinámico (DAST), y pruebas unitarias seguras.	OWASP ZAP, Burp Suite, Selenium Security Testing
5. Despliegue	Configuraciones inseguras del servidor o base de datos; exposición de credenciales, proveedores de hosting sospechosos o gratuitos dónde no la seguridad no esté contemplada.	Asegurar el entorno de producción, aplicar controles de acceso, cifrado TLS/SSL y gestión de credenciales o accesos a servidores.	CIS Benchmarks, Docker Security, Vault
6. Mantenimiento	Vulnerabilidades no corregidas, parches pendientes, monitoreo deficiente, nula	Aplicar gestión continua de parches, auditorías periódicas y monitoreo de seguridad en tiempo real.	SIEM, Nessus, ISO 27005, OWASP Dependency-Check

Fase del SDLC	Riesgos o Amenazas	Controles o Medidas de Seguridad	Herramienta / Estándar Sugerido
	actualización de librerías o frameworks.		

Conclusiones

La seguridad se debe contemplar e ir aplicando en cada fase del Ciclo de Vida del Desarrollo de Software, ya que desde el momento de pedir requerimientos se debe realizar un análisis de riesgos, para de esta manera ya tener claro que datos no deben ser accesibles para cualquiera por ejemplo, pero no solo eso, si no qué, si se contempla la seguridad desde el inicio del ciclo del desarrollo facilita más la propia implementación y esto hace que el desarrollo sea escalable y cada vez que requiera una modificación no implique costos innecesarios o demoras ya que como se contemplo desde el inicio ya será todo más "modificable", además el implementar la seguridad desde el inicio no solo reduce riesgos técnicos, sino que también aumenta la confianza de los usuarios y el cumplimiento normativo. En este caso, la aplicación de estándares reconocidos como ISO 27001, OWASP ASVS y CIS Benchmarks asegura una gestión sistemática de la seguridad desde la planificación hasta la operación continua. Implementar un SDLC seguro permite que la seguridad deje de ser un añadido final para convertirse en un componente esencial del proceso de desarrollo, garantizando así la protección de los datos médicos y personales que maneja la aplicación.